Title: Security Reporting and Visualization of Web Application Vulnerabilities

Objective

The objective of this lab is to understand how to create structured security reports, document vulnerabilities, and communicate findings effectively to both technical and non-technical stakeholders. It also focuses on visualizing attack paths using diagrams for better understanding of security risks.

Tools Used

1. Google Docs

Google Docs is used to create structured penetration testing reports including executive summary, technical findings, and remediation plans.

2. Draw.io

Draw.io is used to design visual diagrams such as network attack paths to represent how vulnerabilities can be exploited.

Report Structure

Executive Summary

Provides a high-level overview of security issues, impact, and recommendations for management.

Technical Findings

Describes vulnerabilities in detail, including how they were discovered and their impact.

Remediation Plan

Suggests corrective actions to fix vulnerabilities and improve system security.

Findings Table

A Findings Table is a summarized report of all vulnerabilities discovered during testing.

Finding ID	Vulnerability	CVSS Score	Remediation
F001	SQL Injection	9.1	Input validation
F002	Weak Password	7.5	Enforce complexity

Visualization (Attack Path Diagram)

An attack path diagram was created using Draw.io to show how an attacker can exploit vulnerabilities step-by-step.

Attacker → Web Application → SQL Injection → Database Access → Data Theft

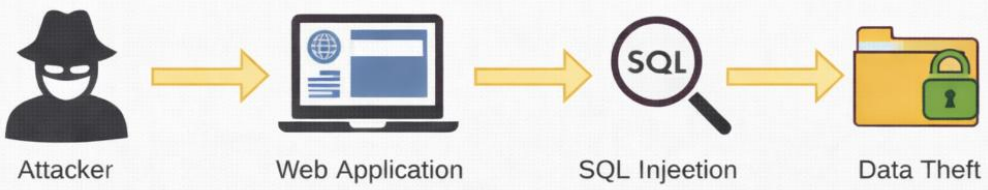

*Figure 1: Network attack path diagram illustrating exploitation flow

Findings

The findings section describes the security issues identified during testing, along with their impact on the system.

SQL Injection (F001):

This vulnerability allows attackers to manipulate database queries by injecting malicious SQL code into input fields. As a result, attackers can access sensitive data such as usernames, passwords, and other confidential information. In severe cases, it can lead to complete database compromise.

Weak Password (F002):
Weak or easily guessable passwords reduce the effectiveness of authentication mechanisms. Attackers can exploit this by performing brute-force or dictionary attacks to gain unauthorized access to user accounts, including administrative accounts.

These findings indicate that the application lacks proper input validation and secure authentication controls, making it vulnerable to attacks

Remediation

The remediation section provides solutions to fix identified vulnerabilities and improve security.

Input Validation and Sanitization:

All user inputs should be validated and filtered to prevent malicious data from being processed by the application.

Use of Prepared Statements:

Parameterized queries should be used instead of dynamic SQL queries to prevent SQL Injection attacks.

Strong Password Policies:

Enforce complex passwords (minimum length, special characters, etc.) and avoid common or default passwords.

Secure Authentication Mechanisms:

Implement features like account lockout after multiple failed attempts and session timeout to prevent unauthorized access.

Regular Updates and Security Testing:

Keep the system updated and perform periodic vulnerability assessments.
These measures help in reducing risk and strengthening application security.

Conclusion

The lab demonstrated how common web application vulnerabilities such as SQL Injection and weak authentication can significantly impact system security. It highlighted the importance of using both manual and automated testing techniques to identify these issues. The findings emphasize the need for secure coding practices, proper validation mechanisms, and regular security assessments. By implementing the recommended remediation steps, the application can be made more secure and resilient against potential cyberattacks.

Proper testing + proper fixes = secure system

Non-Technical Brief

The security assessment identified critical vulnerabilities in the web application that may expose sensitive data and allow unauthorized access. The most significant issues include SQL injection and weak password policies. These vulnerabilities can lead to data breaches, financial loss, and damage to the organization’s reputation. Immediate action is required to improve input validation and enforce strong password controls. Additionally, implementing regular security testing and monitoring

will help prevent future attacks. Addressing these issues will enhance the overall security and reliability of the system.